PORTFOLIO SUMMARY

Application Security Review

Acme Corp | Q3 2026 | 3 applications reviewed

2 of 3 approved

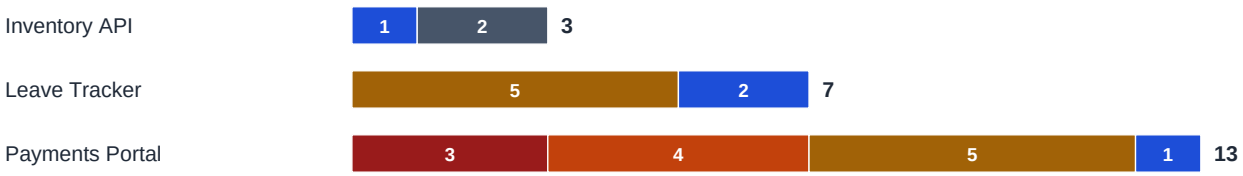
1 blocked, 1 approved with conditions, 1 approved clean

Where we stand

Three applications at different tiers went through the review process this quarter. They were chosen to show the full range of outcomes: one blocked for release, one approved with a condition, and one clean. **23 findings** in total (3 Critical, 4 High, 10 Medium, 4 Low, 2 Informational). The automated pipeline gate passed 2 of 3 applications, matching the review outcome for all three on the Critical and High findings it can see.

Application	Tier	Decision	Pipeline gate	Findings (C/H/M/L/I)
Acme Inventory API ASR-2026-033	Tier 3 (standard)	**Approved**	**PASS**	0 / 0 / 0 / 1 / 2
Acme Leave Tracker ASR-2026-038	Tier 2 (important)	**Approved with conditions**	**PASS**	0 / 0 / 5 / 2 / 0
Acme Payments Portal ASR-2026-041	Tier 1 (critical)	**Not approved**	**FAIL**	3 / 4 / 5 / 1 / 0

Findings by application and severity



Legend: **Critical** **High** **Medium** **Low** **Info**

What the pipeline sees and what it does not

17 of 23 findings were detected or confirmed by the automated pipeline. The 6 findings below were found **only by manual review**. They cluster in access control, logging and design, which pattern-matching tools cannot judge. The pipeline is the first filter; the review is still needed.

Finding	Application	Class	Severity
INV-01 No throttling on failed API-key attempts	Inventory API	A07:2021 Identification and Authentication Failures	**Low**
INV-02 One shared API key for all clients	Inventory API	A04:2021 Insecure Design	**Info**
INV-03 Publish the SBOM and monitor it continuously	Inventory API	A06:2021 Vulnerable and Outdated Components	**Info**
LV-01 Insecure direct object reference on leave records	Leave Tracker	A01:2021 Broken Access Control	**Medium**

Finding	Application	Class	Severity
LV-07 No audit trail for HR exports	Leave Tracker	A09:2021 Security Logging and Monitoring Failures	**Low**
PAY-13 No audit logging or rate limiting for sensitive actions	Payments Portal	A09:2021 Security Logging and Monitoring Failures	**Medium**

Recurring themes

OWASP Top 10 (2021) category	Findings
A01:2021 Broken Access Control	**3**
A02:2021 Cryptographic Failures	**2**
A03:2021 Injection	**2**
A04:2021 Insecure Design	**1**
A05:2021 Security Misconfiguration	**7**
A06:2021 Vulnerable and Outdated Components	**3**
A07:2021 Identification and Authentication Failures	**3**
A09:2021 Security Logging and Monitoring Failures	**2**

The review process

Step	What happens	Owner
Intake	Team submits the questionnaire; AppSec assigns a tier (1 critical, 2 important, 3 standard).	Product team / AppSec
Pipeline	Secrets, SAST, dependency, IaC, container, SBOM and DAST run on every push and on request.	Pipeline (automated)
Manual review	Threat model, access-control and logic review, authenticated testing. Depth set by tier.	AppSec
Report	Findings scored with CVSS, mapped to CWE/OWASP, with owner and due date.	AppSec
Remediate and re-test	Fixes verified by re-test; the pipeline gate must pass with no Critical or High waivers.	Product team / AppSec
Sign-off	Decision recorded: approved, approved with conditions, or not approved.	AppSec / product owner

Recommendations

1. Make the pipeline gate a required check on the main branch of every Tier 1 and Tier 2 application.

2. Add a two-user authorisation test to every service that exposes objects by id, to catch the IDOR class automatically after the first review.

3. Centralise error handling and security headers in a shared library; both are repeated findings.

4. Enable dependency update automation and store an SBOM per release.

5. Move secrets to the platform secrets manager and add pre-commit secret scanning.